CARD 1 | Samsung, 2023

# The code that went to a chatbot

## What was reported

- Samsung Electronics' semiconductor division began allowing staff to use ChatGPT on 11 March 2023, according to Economist Korea.
- The same outlet reported on 30 March 2023 three cases of staff entering company material into it: two with source code and one with meeting content. One engineer was reported to have pasted the source code of a program that handles semiconductor equipment measurement data, to get help fixing an error.
- On 2 May 2023 Bloomberg reported a Samsung memo banning generative AI tools on company devices. As reported, the memo said engineers had accidentally leaked internal source code by uploading it to ChatGPT.
- Reporting differs on the month (March in the Korean reports, April in the report of the memo). Samsung did not say what the code contained, and no misuse of the data was reported.

**The question for your pair**

**Nobody broke into anything. Which rule or control would have applied before the first paste, and who at CSOB would have been asked?**

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Economist Korea (30 March 2023) as summarised by NHIMG; Bloomberg (2 May 2023) via Business Standard, Business Insider and Forbes Australia; The Register (2 May 2023).

CARD 2 | Italy, December 2024

# The regulator's decision

## What was reported

- On 20 December 2024 the Italian data protection authority (the Garante) fined OpenAI 15 million euros over ChatGPT.
- It said OpenAI had processed users' personal data to train ChatGPT without first identifying an adequate legal basis, and had breached the transparency principle and its information obligations to users. It also ordered a six-month public information campaign in Italian media.
- Reports describe it as the first significant GDPR fine against a major generative AI provider in Europe. The investigation began in March 2023, when the Garante imposed a temporary limit on ChatGPT in Italy.
- OpenAI called the fine disproportionate and said it would appeal.

**The question for your pair**

**The finding was about training a model, not about a bank. What is the same question for a bank's own agent: what is the legal basis for each use of personal data, and where is it written down?**

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Garante announcement, 20 December 2024, as reported by AP (via accesswdun.com), Bloomberg Law, The Hacker News, Lewis Silkin (14 January 2025) and Syrenis.

CARD 2 | February 2024

# The chatbot the airline had to honour

## What was reported

- A customer asked an airline's website chatbot about bereavement fares after a family death. The chatbot told him he could apply for the reduced fare retroactively within 90 days.
- The airline's actual policy said otherwise. A link in the chatbot's answer led to the correct policy page. The airline refused the refund.
- In a decision published on 14 February 2024, a British Columbia tribunal found the airline liable for negligent misrepresentation, said it had not taken reasonable care to ensure its chatbot was accurate, and ordered it to pay roughly C$812 including damages, interest and fees.
- The airline had argued the chatbot was a separate entity responsible for its own actions. The tribunal called that a remarkable submission.

**The question for your pair**

**Which part of "telling a customer what the refund policy says" could be a rule, and which part needs the model at all?**

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Civil Resolution Tribunal of British Columbia decision, 14 February 2024, as reported by Kiplinger, Fox Business, ITWire and Norton Rose Fulbright.

CARD 3 | September 2025

# One line of code, 1,643 downloads

## What was reported

- Security researchers at Koi Security reported what they described as the first malicious MCP server seen in the wild: an npm package called postmark-mcp.
- It copied the code of the real Postmark MCP server, which is published on GitHub, not npm. The publisher released fifteen versions that behaved normally.
- In version 1.0.16, released on 17 September 2025, one added line blind-copied every email sent through the server to an address the publisher controlled.
- Reports put the package at about 1,500 downloads in a week and 1,643 in total before it was removed. The emails could include password resets, invoices and customer correspondence.

**The question for your pair**

**You run the intake checklist. Which line would have caught this, and at which moment: the first install, or a later version change?**

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Koi Security as reported by The Hacker News (via ThaiCERT), SC Media, Dark Reading, The Register (29 September 2025).